TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Taiwan-based lone attacker used BOSSAI AI agents against hundreds of organizations

From **Cybersecurity Briefing** · 2026-11-08 to 2026-11-09 (stretched to 2026-11-04) · Briefing generated 2026-11-09

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261112-02	1.0 · 2026-11-12 15:02 EST	TLP:CLEAR	Global
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-04	2026-11-09	None	Nick Sturgeon

THREAT ACTIVITY **HIGH** PUBLICLY DISCLOSED; OPERATOR NOT REPORTED ARRESTED; INFRASTRUCTURE STATUS UNKNOWN

OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 4 November 2026 the Acronis Threat Research Unit (TRU) published an analysis of BOSSAI, an attack setup built from 12 AI agents (nine in active use) and run by one person. TRU assesses with high confidence that the operator is in Hualien City, Taiwan, based on a reused handle, branding, an SSH key identity that matches a GitHub account, and a home IP address that leaked into one of his own chatbot sessions [S1]. The evidence comes from the operator's own exposed server, which held more than 90,000 files (about 9 GB) of agent conversations, command history, tools, credentials and victim data [S1] [S2]. The Hacker News and other outlets reported the findings between 4 and 9 November [S3] [S4] [S5] [S6].

The agents were pointed at hundreds of organizations in 11 countries, but the confirmed damage is much smaller: about 10 targets in Taiwan, Thailand and Mexico had data taken or systems accessed, and about 15 more were attacked without a confirmed break-in [S1] [S4]. Confirmed outcomes include case records pulled from a Taipei 119 emergency dispatch API, a Taipei fire department patient platform that exposed 2018 ECG readings, vitals and ambulance video without a login, a fire-dispatch vendor's database admin panel entered with default root credentials, account data taken from a Taiwanese lender through SQL injection, and data extracted from three Thai universities through SQL injection [S1]

[S3]. The roughly 206,800 Mexican residential phone records and about 124,000 directory listings were assembled by scraping, not by breaching the underlying systems [S1] [S4]. Sources differ on whether the Taipei patient records were stolen or only exposed [S3].

The method was unsophisticated. Commercial models (Grok, MiniMax M3) refused attack requests, so the operator ran offensive work on locally hosted models with their safety training removed (variants of DeepSeek, GLM and Qwen). Those models drove ordinary tools such as sqlmap, nmap, nikto, Hydra, Metasploit and a cracked Acunetix scanner, and they frequently invented findings: more than half of one agent's high and critical results were false or misclassified [S1] [S3]. Every success involved a weakness that was already open (an unauthenticated API, default credentials, legacy Oracle and MSSQL databases with injectable pages). The agents failed where logins were enforced, sessions were required and inputs were filtered [S3].

No CVE is named, no malware hashes were published, and there is no evidence in the sources of United States victims beyond reconnaissance [S1]. Acronis published nine IP addresses and nine domains without activity status or, for most, any note on their role [S1] [S3]. Defenders should block and hunt for those indicators at low cost, but the more useful response is basic exposure hygiene: find internet-facing apps and APIs that answer without authentication, remove default credentials from admin panels, fix or isolate legacy databases, and alert on scanner bursts and SQL injection patterns in web logs.

Key judgments

LIKELY · MODERATE CONFIDENCE
Other low-skill individuals will likely copy this model (safety-stripped local models wired to standard scanning and SQL injection tools) over the next 6 to 12 months, raising the volume of opportunistic attacks against exposed web applications and APIs in all regions. [S1] [S2] [S3] [S4]

VERY UNLIKELY · MODERATE CONFIDENCE
Organizations that enforce authentication on public APIs, remove default credentials and patch or isolate legacy databases are very unlikely to be breached by a BOSSAI-style operation, because the agents in this case failed against every control that was actually in place. [S1] [S3] [S6]

UNLIKELY · LOW CONFIDENCE
It is unlikely that the published IP addresses and domains will produce hits in Indiana or other United States networks; the operator's United States activity was limited to reconnaissance, the indicators have no activity status, and rented servers and free subdomains are easy to replace after disclosure. [S1] [S3]

LIKELY · LOW CONFIDENCE
The single-operator attribution will likely hold, since it rests on several independent operational-security errors, but the motive (probably financial) and any tie to a sponsor remain open and could change with further reporting or law-enforcement action in Taiwan. [S1] [S3] [S7]

INDICATORS OF COMPROMISE

All reported indicators come from the indicator list and body text of the Acronis TRU report published 2026-11-04, as retrieved on 2026-11-12; two outlets repeat a subset. It is a single-vendor list with no activity status and, apart from the primary node, no mapping of indicators to roles. Several domains sit under what appear to be free or shared subdomain services, so block the full host names only, not the parent zones. Personal identifiers of the suspected operator that appear in the Acronis report are deliberately not reproduced here.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`112[.]121[.]185[.]218`	Primary BOSSAI node (called vps12 by Acronis). Hosted the agent command interface on 80/443 and tooling on 18080, 5001, 8000, 8443 and 3000.	REPORTED		[S1] [S5] [S6]
ipv4	`156[.]240[.]109[.]26`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1] [S6]
ipv4	`49[.]158[.]237[.]136`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1] [S6]
ipv4	`202[.]160[.]76[.]153`	Listed in the Acronis indicator list; role not stated. One of six addresses in the same /24.	REPORTED		[S1]
ipv4	`202[.]160[.]76[.]154`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
ipv4	`202[.]160[.]76[.]155`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
ipv4	`202[.]160[.]76[.]156`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
ipv4	`202[.]160[.]76[.]157`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
ipv4	`202[.]160[.]76[.]174`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
domain	`vps[.]xs1[.]ccwu[.]cc`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1] [S6]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`xss[.]xs1[.]ccwu[.]cc`	Listed in the Acronis indicator list; role not stated. The host name suggests cross-site scripting payload hosting or callback collection, but that is an inference from the name only.	REPORTED		[S1] [S6]
domain	`c[.]xs1[.]ccwu[.]cc`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1] [S6]
domain	`attacker-collector[.]com`	Listed in the Acronis indicator list; role not stated. The name reads like a placeholder from a payload template, so treat a hit as low confidence until confirmed.	REPORTED		[S1]
domain	`boss[.]jytian[.]cc[.]cd`	Listed in the Acronis indicator list; role not stated. Matches the operator's 'boss'/'jy' naming.	REPORTED		[S1]
domain	`gdp[.]gasjy[.]kdns[.]fr`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
domain	`gds[.]gasjy[.]kdns[.]fr`	Listed in the Acronis indicator list; role not stated.	REPORTED		[S1]
domain	`888[.]bossjy[.]kdns[.]fr`	Listed in the Acronis indicator list; role not stated. Contains the 'bossjy' handle tied to the operator.	REPORTED		[S1]
domain	`ssh[.]gputw[.]ai`	Listed in the Acronis indicator list; role not stated. Name suggests SSH access to GPU compute.	REPORTED		[S1]
port	`8443/tcp on 112.121.185.218`	Custom post-exploitation framework ('Oktos Adaptive Offensive') on the primary node.	REPORTED		[S1]
port	`8000/tcp on 112.121.185.218`	HexStrike AI tool server (MCP) on the primary node.	REPORTED		[S1]
port	`5001/tcp on 112.121.185.218`	Kali tool server (MCP) on the primary node.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`18080/tcp on 112.121.185.218`	Web terminal ('Zen Terminal') on the primary node.	REPORTED		[S1]
port	`3000/tcp on 112.121.185.218`	Page carrying the operator's team branding on the primary node.	REPORTED		[S1]
port	`80/tcp and 443/tcp on 112.121.185.218`	Agent (OpenClaw) control interface on the primary node.	REPORTED		[S1]
filename	`webai_poc.py`	Script found on the operator's server. An attacker-side artifact; not expected on victim hosts.	REPORTED		[S1]
filename	`888.txt`	File found on the operator's server; purpose not stated. Attacker-side artifact.	REPORTED		[S1]
filepath	`/tmp/weixin-qr/login-qr.png`	QR code file on the operator's server used in attribution (messaging account link). Attacker-side artifact.	REPORTED		[S1]
other	`HERMES_YOLO_MODE=1`	Environment variable on the operator's server that let the main attack agent run commands without approval. Attacker-side artifact.	REPORTED		[S1]
other	`HERMES_ACCEPT_HOOKS=1`	Environment variable on the operator's server. Attacker-side artifact.	REPORTED		[S1]
other	`bossjy`	Handle used across the operator's infrastructure and in one indicator domain.	REPORTED		[S1] [S5]
user-agent	`sqlmap/`	Derived. sqlmap was the operator's most used attack tool and sends a user agent beginning 'sqlmap/' unless told to randomize it. The sources do not say which user agent was used, so absence of this string proves nothing.	DERIVED		[S1] [S5]
user-agent	`Nikto`	Derived. nikto was used for scanning and identifies itself with 'Nikto' in the user agent by default. Not stated in the sources.	DERIVED		[S1] [S5]
http-request	`POST /xmlrpc.php (repeated, many credential pairs)`	Derived. The operator ran credential stuffing against WordPress XML-RPC (more than 2,600 combinations, no valid logins); that technique must hit this path on a default WordPress install.	DERIVED		[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

One operator ran a set of AI coding and chat agents, each with a narrow job, and acted as the only link between them by pasting one agent's output into the next. Commercial cloud models built and maintained his servers and tools but refused direct attack requests, so attack agents were pointed at locally hosted open-weight models with safety training removed (DeepSeek, GLM and Qwen variants), running on rented and owned GPUs. Through tool servers (HexStrike AI, a Kali server, a Ghidra bridge) those agents searched Shodan and FOFA for targets, scanned with nmap, nikto, a cracked Acunetix and directory brute-forcers, then tried SQL injection with sqlmap, default and brute-forced logins with Hydra and custom scripts, and a web shell upload through an unnamed known flaw (which failed). Traffic was routed through a SOCKS5 pool and commercial datacenter proxies. Data came out through injectable database pages, unauthenticated APIs and an admin panel with default root credentials. The agents often reported vulnerabilities and results that did not exist.

Threat actor

BOSSAI operator (unnamed individual) · also tracked as bossjy, AI-augmented threat (Acronis category label)

Attribution confidence: Moderate · **Motivation:** Probably financial, per the researchers; not established. Some targeting (government, emergency, military) resembles espionage, other targeting resembles ordinary cybercrime. · **Suspected origin:** Hualien City, Taiwan (Acronis assessment, stated as high confidence)

Acronis states high confidence; this report grades it Moderate because it is a single-vendor assessment that no government or second research team has confirmed. Evidence cited: one handle and team branding across servers, an SSH key identity matching a GitHub account, a GitHub profile tied to a legitimate business, and a residential IP exposed in the operator's own chatbot session. No arrest or charge is reported. The briefing describes this activity as unrelated to the campaign it calls ARTEX; the sources opened for this report do not use that name, but two note that separately reported AI-assisted attacks on Taiwanese government agencies are not linked to BOSSAI.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1588.007 Obtain Capabilities: Artificial Intelligence	Used commercial models (Grok, MiniMax M3, and coding agents) for building infrastructure and locally hosted safety-stripped DeepSeek, GLM and Qwen variants for attack tasks. [S1] [S3]	Not visible to victims. Relevant to AI providers and to organizations governing internal AI agent use.
Resource Development	T1588.002 Obtain Capabilities: Tool	Assembled sqlmap, nmap, nikto, Metasploit, Hydra, gobuster, dirsearch, ffuf, a cracked Acunetix scanner and a custom Hikvision exploitation tool. [S1] [S5]	Web and firewall logs showing default signatures of these tools.
Resource Development	T1583.003 Acquire Infrastructure: Virtual Private Server	Ran a fleet of nine VPS nodes (gateway, VPN, lab, mail and others) plus GPU hosts tunneled to the primary node. [S1]	Match outbound and inbound connections against the reported IPs and domains.
Reconnaissance	T1596.005 Search Open Technical Databases: Scan Databases	Queried Shodan and FOFA to find exposed systems by technology and country. [S1] [S5]	Not directly observable. Review your own footprint in those services.
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Agents scanned hundreds of sites, including 489 targets at 45 Thai institutions, with nmap, nikto, Acunetix and LLM-driven scanners. [S1] [S4]	Bursts of 404s and scanner user agents from one source; WAF scanner rules.
Reconnaissance	T1595.003 Active Scanning: Wordlist Scanning	Used gobuster, dirsearch and ffuf to find hidden paths and admin panels. [S1]	High rate of requests to non-existent paths from a single client.
Initial Access	T1190 Exploit Public-Facing Application	SQL injection (including boolean-based blind) against a legacy Oracle 9.2 site and an MSSQL 2017 application with 16 injectable points; unauthenticated API and data-port access at emergency services. [S1] [S3]	SQL keywords and time or boolean probes in query strings; database errors in web logs; large responses from API endpoints to unauthenticated clients.
Initial Access	T1078.001 Valid Accounts: Default Accounts	Logged in to a fire-dispatch vendor's database admin panel with default root credentials and reached 18 or more tables. [S1] [S3]	Successful root or admin logins to database admin panels from external addresses.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1110.001 Brute Force: Password Guessing	Brute-forced a national fire agency single sign-on portal, an employee authentication system and WooCommerce logins; none confirmed successful. [S1] [S3]	Many failed logins per source or per account; lockout events.
Credential Access	T1110.004 Brute Force: Credential Stuffing	Sent more than 2,600 credential pairs to WordPress XML-RPC; no valid logins. [S1]	Repeated POSTs to xmlrpc.php, especially system.multicall.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Recovered a hardcoded AES-256 key from front-end JavaScript and used it to read session cookie contents, including an administrator identity. [S1] [S3]	Secret scanning of shipped JavaScript; hard to detect in logs.
Persistence	T1505.003 Server Software Component: Web Shell	Attempted a web shell upload through an unnamed known vulnerability at a fire-dispatch vendor (failed); the custom Hikvision tool also includes web shell upload. [S1] [S3]	New script files in web roots; web server processes spawning shells.
Collection	T1213 Data from Information Repositories	Dumped database tables through injection (one Oracle admin table of 2,563 rows) and pulled dispatch case records from a public API. [S1] [S4]	Unusual row counts or sequential enumeration from a single client; database audit logs.
Command and Control	T1090.002 Proxy: External Proxy	Routed attack traffic through an operator SOCKS5 pool and commercial datacenter proxies. [S1]	The same attack pattern arriving from rotating datacenter addresses; rate-limit on behavior, not source IP alone.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Network connections to reported BOSSAI infrastructure `KQL`

```
let bossai_ips =
dynamic(["112.121.185.218","156.240.109.26","49.158.237.136","202.160.76.153","202.160.76.154","202.160.76.155","202.160.76.156","202.160.7
6.157","202.160.76.174"]);
let bossai_domains = dynamic(["vps.xs1.ccwu.cc","xss.xs1.ccwu.cc","c.xs1.ccwu.cc","attacker-
collector.com","boss.jytian.cc.cd","gdp.gasjy.kdns.fr","gds.gasjy.kdns.fr","888.bossjy.kdns.fr","ssh.gputw.ai"]);
DeviceNetworkEvents
| where Timestamp > ago(180d)
| where RemoteIP in (bossai_ips) or RemoteUrl has_any (bossai_domains)
| project Timestamp, DeviceName, ActionType, LocalIP, RemoteIP, RemotePort, RemoteUrl, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc
```

Microsoft Defender for Endpoint schema. Run the same lists against firewall, proxy, DNS and web server logs (inbound source IP matters most here, since these are attack origins). Indicators have no activity status; expect few or no hits.

Scanner and SQL injection tool user agents in web server logs `SIGMA`

```
title: Offensive Scanner User Agents Seen In BOSSAI Reporting
status: experimental
logsource:
  category: webserver
detection:
  selection:
    cs-user-agent|contains:
      - 'sqlmap/'
      - 'Nikto'
      - 'Hydra'
      - 'gobuster'
      - 'dirsearch'
      - 'Fuzz Faster U Fool'
      - 'Nmap Scripting Engine'
      - 'acunetix'
  condition: selection
fields:
  - c-ip
  - cs-uri-stem
  - cs-uri-query
  - sc-status
falsepositives:
  - Authorized penetration tests and vulnerability scans
level: medium
```

Default tool signatures only. An operator can randomize the user agent, so pair this with the behavioral query below.

SQL injection probing burst from a single client `SPLUNK SPL`

```
index=web sourcetype IN (iis, access_combined, nginx:plus:access)
| eval q=lower(urldecode(coalesce(uri_query, cs_uri_query, "")))
| where match(q, "(union(\s|\+|/\*.*?\*/)+select|\band\s+\d+=\d+|\bor\s+\d+=\d+|waitfor\s+delay|sleep\(\d+\)|benchmark\(|
information_schema|all_tables|utl_inaddr|dbms_pipe|xp_cmdshell|@@version)")
| bin _time span=10m
| stats count AS probes dc(uri_path) AS paths values(status) AS statuses BY _time, src_ip
| where probes >= 20
| sort - probes
```

Adjust index, sourcetype and field names. Covers MSSQL and Oracle patterns matching the databases named in the reporting. Follow up any source that also received HTTP 200 responses with unusually large bodies.

WordPress XML-RPC credential stuffing `SPLUNK SPL`

```
index=web uri_path="/xmlrpc.php" http_method=POST
| bin _time span=15m
| stats count AS posts BY _time, src_ip, host
| where posts >= 50
| sort - posts
```

Threshold is a starting point. Disable XML-RPC where it is not needed, which removes the need for this hunt.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Internet-facing web applications and APIs (any vendor)	Applications with SQL injection flaws or endpoints that return data without authentication	No vendor fix applies; correct the application and enforce authentication	None named	N/A	N/A	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Legacy database back ends (Oracle 9.2, Microsoft SQL Server 2017 were the reported cases)	Unsupported or unpatched databases reachable through public web applications	Upgrade to a supported release or remove public reachability	None named	N/A	N/A	No	N/A
Database and device admin panels (including Hikvision cameras, targeted by a custom tool)	Panels exposed to the internet with default or weak credentials	Change credentials; restrict to VPN or management network; apply current vendor firmware	None named	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Add the nine IP addresses and nine full host names to firewall, proxy, DNS and WAF block lists. Block host names exactly as listed; do not block the parent zones, which appear to be shared services. `SOC` [S1] [S5]
- Search web server, WAF, firewall and DNS logs as far back as retention allows (the operator was active by at least late July) for the indicators, with priority on inbound traffic from the listed IPs. `SOC` [S1] [S3]
- Check every internet-facing database admin panel, camera and appliance for default credentials and change any found. `IT OPS` [S1] [S4] [S5]
- Confirm WAF SQL injection and scanner rule sets are in blocking mode, not log-only, for public applications. `IT OPS` [S4] [S5]

Short term (1–7 days)

- Inventory internet-facing applications, APIs and open ports from the outside (external scan plus a Shodan-style lookup of your own address space) and close or put behind authentication anything that returns data without a login. `IT OPS` [S1] [S2] [S4]
- Run an authenticated and unauthenticated web application scan against public sites, prioritize SQL injection findings, and fix or virtually patch them. `IT OPS` [S1] [S6]
- Deploy the scanner user agent, SQL injection burst and XML-RPC hunts as scheduled detections; add rate limiting and lockout on login pages and single sign-on portals. `SOC` [S1] [S4]
- Disable WordPress XML-RPC where not required and require MFA for all administrative and remote logins. `IT OPS` [S1]
- Scan shipped front-end code and repositories for hardcoded keys and secrets; rotate any found. `IT OPS` [S1] [S3]

Long term

- Retire or isolate unsupported database platforms and legacy subdomains; fund replacement where a business application depends on them.

LEADERSHIP [S1] [S4]

- Adopt continuous external attack surface monitoring, on the assumption that every exposed service will be found and tested by automated tools. LEADERSHIP [S1] [S2]
- Set policy for internal AI agents: least-privilege tool permissions, execution logging, and human approval for sensitive actions. LEADERSHIP [S2] [S4]
- Require third-party vendors that host your data (dispatch, records, portals) to attest to authentication on APIs and removal of default credentials. LEADERSHIP [S1] [S3]

Workarounds & compensating controls

- Where a vulnerable legacy application cannot be fixed quickly, place it behind a WAF with strict SQL injection rules, restrict access by source network or VPN, and run the database account with read-only, least-privilege rights. IT OPS [S1] [S4]
- Enable database auditing and alert on bulk reads of account or admin tables by the web application account. SOC [S1] [S2]
- Geo- or reputation-based throttling of datacenter and proxy ranges on login and API endpoints that serve only local users. IT OPS [S1]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Acronis Threat Research Unit: BOSSAI: Inside the AI attack mesh that targeted Taiwan's emergency services
Published 2026-11-04 · A2 Completely reliable, probably true
Primary source and the only origin of the indicators and attribution. Original researchers with direct access to the operator's exposed server. Not independently confirmed. Internally inconsistent on one duration (12-day observation window versus 19 days of model rotation).

[S2] Acronis Blog: Acronis researchers uncover AI attack mesh targeting emergency services
Published 2026-11-04 · A2 Completely reliable, probably true
Vendor summary of S1 with recommendations; page updated 2026-11-08. No indicators.

[S3] The Hacker News: Taiwan-Based Hacker Used BOSSAI AI Agents to Steal Taipei Emergency Dispatch Records
Published 2026-11-09 · B2 Usually reliable, probably true
Briefing source. Secondary reporting on S1; points out the exposed-versus-stolen discrepancy and that indicators carry no activity status. Does not reproduce the indicators.

[S4] eSecurity Planet: One Hacker Used 12 AI Agents to Target Taiwan's Emergency Services
Published 2026-11-04 · `B2` Usually reliable, probably true
Secondary reporting on S1 with defensive recommendations; clarifies that the Mexico data was scraped and that separately reported AI-assisted campaigns are not linked.

[S5] SecurityOnline (Daily CyberSecurity): Lone Hacker Uses BOSSAI Attack Mesh to Breach Taiwan Emergency Services and Universities
Published 2026-11-09 · `C3` Fairly reliable, possibly true
Secondary reporting on S1. Repeats the primary node IP. States the GPU cluster was in Guangzhou, a detail not confirmed in the other sources opened.

[S6] GBHackers: AI-Powered BOSSAI Attacks Expose Patient Records and Emergency Dispatch Data in Taiwan
Published 2026-11 · `C3` Fairly reliable, possibly true
Secondary reporting on S1; exact date not shown on the page. Repeats three IPs and three domains. Says the operator had no clear political or financial goal, which differs from S3. Mentions separate government-reported AI-assisted attacks in Taiwan.

[S7] iThome (Taiwan): iThome news item 180310 on BOSSAI
Published · `F6` Reliability cannot be judged, truth cannot be judged
Could not be opened (HTTP 403). Listed only as a place to watch for statements from Taiwanese authorities; no facts in this report rely on it.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2018	Year of the oldest patient records later found exposed on the Taipei fire department patient platform.	[S1] [S3]
2026-07-25	Operator asked Grok to port his Hikvision exploitation tool to Linux and was refused. Date is from the recovered conversation; The Hacker News notes the year is not stated explicitly.	[S1] [S3]

Date	Event	Source
	Acronis observed the operation for 12 days (exact dates not published); the main attack agent's configuration backups cover 19 days.	[S1]
2026-11-04	Acronis TRU published its analysis and indicator list; first press coverage the same day.	[S1] [S2] [S4]
2026-11-08	Acronis blog summary updated.	[S2]
2026-11-09	The Hacker News and SecurityOnline published coverage.	[S3] [S5]

Relevance to Indianapolis, Indiana & managed clients

There is no reported Indiana or United States victim; United States activity in the recovered data was reconnaissance only. The relevance is the method. The systems that fell are the same kinds found across Indiana: county and city 911 and computer-aided dispatch platforms and their vendors, EMS patient-care record systems, university departmental sites on old databases, and small lenders and businesses with aging web applications. Indiana public safety answering points, fire and EMS agencies and their software vendors should confirm that dispatch and patient-care APIs require authentication and that vendor admin panels do not use default credentials. Universities and K-12 districts should look for forgotten legacy subdomains with database back ends. Hospitals and clinics should treat exposed ECG, vitals and video data as HIPAA-reportable if found. Manufacturers and small and mid-size businesses commonly run internet-facing cameras (Hikvision was specifically tooled for), WordPress and WooCommerce sites, all of which this operator attacked. For managed IT service clients, the practical steps are an external exposure review, default-credential sweep, WAF rule check and the log hunts above; clients that already enforce MFA, patch public systems and keep admin interfaces off the internet face little added risk from this kind of actor.

Intelligence gaps

- Whether the published IPs and domains are still active, and what role each plays beyond the primary node; Acronis gives no status or first-seen dates.
- No file hashes, web shell names or request patterns were published, so host-based hunting is not possible from current reporting.
- The 'known CVE' used in the failed web shell attempt and the flaws behind the Hikvision tool are not identified.
- Exact dates of the 12-day observation window and the full period of operator activity.
- Whether victims and Taiwanese authorities were notified, whether the exposed data is still reachable, and whether any law-enforcement action is under way.
- Whether the Taipei patient records were actually copied or only exposed.

- Which United States organizations were scanned; none are named.
- Motive and any sponsor remain unconfirmed; sources disagree (probably financial versus no clear goal).
- The briefing's statement that this is unrelated to a campaign it calls ARTEX could not be checked against a source using that name.

Other notes

- Date note: the briefing lists the original publication as 2026-11-09 (The Hacker News). The underlying Acronis research was published 2026-11-04; this report uses that as the original date and 2026-11-09 as the update.
- Category changed from the briefing's 'Malware' to 'Threat Activity' because no malware family is involved; the tooling is standard offensive software driven by AI agents.
- Headline figures overstate impact: 'hundreds of organizations' were targeted, about 10 were confirmed compromised, and the Mexico data sets were scraped from public or semi-public sources.
- The agents were unreliable: one scanner invented CVEs and a non-existent Apache remote code execution flaw at a national disaster-response center, and the main attack agent reported results that never happened. An agent also declined a Honduran military target as out of scope.
- Commercial model safeguards worked in part: Grok and MiniMax M3 refused attack requests, with one exception where Grok repaired a proof-of-concept script later passed to an attack agent. Coding agents (Claude Code, Codex CLI) were redirected by the operator to a safety-stripped local model rather than their vendors' models.
- The suspected operator's personal and business identifiers appear in the Acronis report and are intentionally left out here; he has not been charged in any source reviewed.
- One indicator domain (attacker-collector[.]com) looks like a template placeholder and one IP may be a residential address; treat single hits on either as low confidence.
- SecurityOnline places the GPU cluster in Guangzhou, China; this was not confirmed in the other sources opened.

CTI-20261112-02 v1.0 · Generated 2026-11-12 15:02 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.